UNIVERSITÉ CHEIKH AHMADOUL KHADIM - UCAK

UFR MET – Département IT / Administration et Sécurité des Réseaux

MISE EN PLACE D'UNE SOLUTION DE GESTION DES VULNÉRABILITÉS (VMS)

Laboratoire EVE-NG reproduisant l'architecture du Data Center du Rectorat
(double liaison FO, cœur IOSv L3, 2 bâtiments, cloud IaaS — 15 nœuds + 2 clouds EVE-NG)

LIVRABLE 3 — SEMAINE 3

Objectif spécifique 4 : « Mettre en place un système de scoring et de priorisation des risques basé sur le CVSS et le contexte métier » (RBVM)

Scans authentifiés L1 (réseau IOS) et L2 (postes, cloud, terminaux)
+ grille de criticité métier + matrice « Risque = CVSS × Criticité »

Réalisé par	Proposition / encadrement	Date	Référentiel
Makane SECK	Dr. Abdoul Aziz CISS (EPT)	09 / 10 / 2026	Docs 03 · 04 · 06 (Atelier A) — livrable 2

1. Objectif du livrable et résultats attendus

Objectif 4 : noter et prioriser les risques en croisant la sévérité technique (CVSS/OpenVAS) avec la criticité métier — la pratique **RBVM** (***Risk-Based Vulnerability Management***). Semaine 3 : scans authentifiés L1 + L2, puis Atelier A (grille + matrice). Prérequis (livrable 2) : GBVA opérationnelle, NVT à jour, baseline P0 exportée, credentials créées (04 §6.5).

#	Résultat attendu	Critère de réussite	Statut
1	Scan authentifié L1 (réseau IOS)	Rapports avant/après + remédiation 03 §7.5 vérifiée	**Fait**
2	Scan authentifié L2 (postes + cloud)	Constats V-01/V-02/V-04/V-05 relevés	**Fait**
3	Grille de criticité métier	Barème 4 critères × 15 actifs rempli et justifié	**Fait**
4	Matrice de risques RBVM	Risque = CVSS × Criticité + priorités P1/P2/P3	**Fait**

2. La méthode RBVM — rappel (réf. 06, Atelier A)

Formule : Risque = Sévérité CVSS (GCE, 0-10) × Criticité métier de l'actif (1-5) → score de 0 à 50.

Priorité	Risque	Délai d'action	Signification
P1 — Immédiate	≥ 25	48 h — 7 jours	faille forte sur un actif vital : correction en premier
P2 — Moyenne	10 – 24	30 jours	à planifier (fenêtre de maintenance)
P3 — Basse	< 10	trimestre / surveillance	impact métier faible

Pourquoi croiser ? Le CVSS mesure la gravité technique intrinsèque ; le risque réel dépend de ce qui héberge la faille. Exemple du cours : 9.8 × 5 (serveur principal) = 49 → P1 ; 9.8 × 1 (PC de test isolé) = 9.8 → P3. C'est ce croisement qui transforme un rapport technique en plan d'action managérial.

3. Grille de criticité métier — université (livrable clé obj. 4)

Chaque actif noté 1 (mineur) à 5 (vital) sur 4 critères ; criticité = moyenne des 4 notes, arrondie à l'entier.

Critère	Question posée	1 (mineur)	3 (modéré)	5 (vital)
C1 — Confidentialité	Que perd-on si les données fuient ?	aucune donnée	données de service d'un bâtiment	dossiers étudiants / configs réseau
C2 — Disponibilité	Quel service s'arrête si l'actif tombe ?	un terminal	un bâtiment	tout le réseau (cœur / FO)
C3 — Exposition	Où se trouve l'actif ?	segment isolé	VLAN métier (30/31)	cloud (10.9.1.0/24) / opérateur
C4 — Rôle	Quelle fonction dans le SI ?	IoT / téléphonie	poste utilisateur / scanner	serveur de données / équipement réseau

Exemples traités : SRV-CLOUD C1=5, C2=4, C3=5, C4=5 → 4,75 → 5 · Windows-10 : 2+2+3+2 → 2,25 → 2.

Actif	C1	C2	C3	C4	Criticité finale
R-CE-1	1	5	5	5	**4**
R-CE-2	1	5	5	5	**4**
R-CE (cœur)	5	5	4	5	**5**
SW-TOR	5	4	4	5	**4**
SW-MET	1	3	3	5	**3**
SW-SMS	1	3	3	5	**3**
GBVA	5	1	3	3	**3**
SRV-CLOUD	5	4	5	5	**5**
Windows-10	2	1	3	3	**2**
Win-7	3	1	3	3	**3**
IP-Phone	1	1	2	1	**1**
Camera	1	1	3	2	**2**

Windows-10-1	2	1	3	3	**2**
Win-7-1	3	1	3	3	**3**
IP-Phone-1	1	1	2	1	**1**

4. Lab 1 — Scan authentifié des équipements réseau (IOS)

But : identifier → remédier → vérifier (constat V-03 : telnet, SNMP v1 public/private, guest — plantés en baseline 03 §7.5).
Politique : Full Scan.

Équipement	IP de scan	Credentials GCE	Constats	CVSS relevé
R-CE-1	172.16.255.1	SNMPv1 public (+ SSH admin)	Telnet Unencrypted Cleartext Login	4,8 (Medium)
R-CE-2	172.16.254.1	idem	Telnet Unencrypted Cleartext Login	4,8 (Medium)
R-CE (cœur)	172.16.30.1	idem	Telnet Unencrypted Cleartext Login	4,8 (Medium)
SW-TOR	172.16.10.2 (SVI)	idem	Telnet Unencrypted Cleartext Login	4,8 (Medium)
SW-MET	172.16.30.2 (SVI)	idem	Telnet Unencrypted Cleartext Login	4,8 (Medium)
SW-SMS	172.16.31.2 (SVI)	idem	Telnet Unencrypted Cleartext Login	4,8 (Medium)

PREUVE 1
Rapport GCE L1 AVANT : constats V-03 visibles sur les 6 équipements (export PDF).

Vulnerability		Severity	QoD	Host		Location	EPSS	
				IP	Name		Score	Percentile
Telnet Unencrypted Cleartext Login		4.8 (Medium)	70 %	172.16.30.1	172.16.30.1	23/tcp	N/A	N/A
Telnet Unencrypted Cleartext Login		4.8 (Medium)	70 %	172.16.255.1	172.16.255.1	23/tcp	N/A	N/A
Telnet Unencrypted Cleartext Login		4.8 (Medium)	70 %	172.16.31.2	172.16.31.2	23/tcp	N/A	N/A
Telnet Unencrypted Cleartext Login		4.8 (Medium)	70 %	172.16.254.1	172.16.254.1	23/tcp	N/A	N/A
Telnet Unencrypted Cleartext Login		4.8 (Medium)	70 %	172.16.30.2	172.16.30.2	23/tcp	N/A	N/A

4.2 Remédiation (03 §7.5, sur les 6 équipements) :

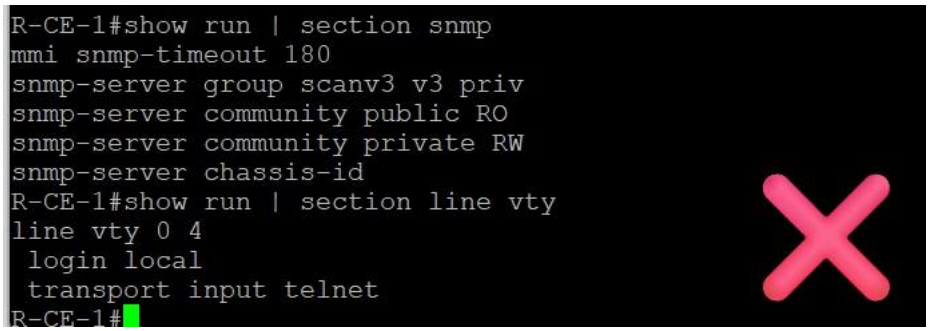
```
line vty 0 4  transport input
ssh no snmp-server community
public no snmp-server community
private no username guest snmp-
server group scanv3 v3 priv
snmp-server user gvm-scan scanv3 auth sha <MOT-DE-PASSE> priv aes 128 <MOT-DE-PASSE> write
memory
```

Vérification	Commande de contrôle	Résultat (O/N)
telnet fermé	nmap -p 23 <IP> → closed	O
SNMP v1/v2c supprimé	show run | section snmp	O
SNMPv3 actif	show run | include gvm-scan|scanv3	O

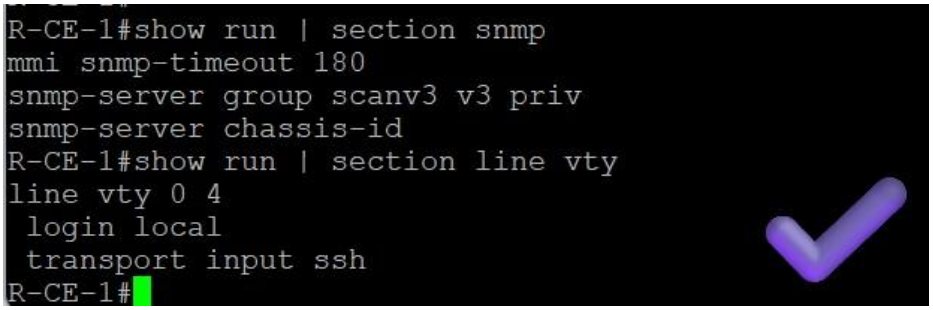
guest supprimé	show run | include guest	O

PREUVE 2

Captures console avant/après : show run | section snmp + lignes vty.



Avant



Après

4.3 Re-scan APRÈS (credential SNMPv3 gvm-scan, auth SHA + priv AES-128) : les constats V-03 ont disparu.

PREUVE 3

Rapport GCE L1 APRÈS : V-03 disparu



Comparaison L1	Avant	Après
Constats totaux	2	1
Sévérité la plus haute	4,8 (Medium)	2,1 (Low)
CVSS V-03 relevé	Telnet Unencrypted Cleartext Login	remédié

5. Lab 2 — Scans authentifiés : postes, cloud et terminaux

But : constats « postes et données » (V-01, V-02, V-04, V-05) sur les 2 bâtiments + le cloud. Cibles : 172.16.30.0/24 + 172.16.31.0/24 + 10.9.1.10 — Full Scan.

Actif	IP	Credential GCE	Constats	CVSS relevé
Windows-10 (MET)	172.16.30.10	WinRM student/Win10Lab-2026	V-02 (Win10 EOL, WinRM clair…)	10,0 (Critical)
Win-7 (MET)	172.16.30.50	WinRM admin/admin	V-01 : EOL + MS17010/SMBv1	10,0 (Critical)
Win-7-1 (SMS)	172.16.31.10	WinRM olduser/Win7Lab-2026	V-01 (même profil)	10,0 (Critical)
Windows-10-1 (SMS)	172.16.31.11	aucun (découverte)	V-02 (non auth.)	10,0 (Critical)
SRV-CLOUD	10.9.1.10	SSH scan/Win-Lab-2026 (sudo)	Réel 07/10 : auth SSH OK · Sudo CVE-2021-3156 7.8 (H) · 8 mitigations CPU (M) · weak MAC SSH + timestamps (B) — pas d'EOL GCE, :80 fermé	7,8 (High)
Camera (MET)	172.16.30.11	aucun (volontaire)	V-05 : web :80, admin/1234	4,8 (Medium)

5.2 Complément Nmap :

```
nmap --script smb-vuln-ms17-010,smb2-security-mode 172.16.30.50 172.16.31.10 #
=> MS17-010 VULNERABLE sur les 2 Win-7
```

PREUVE 4

Rapport GCE L2 AVANT + sorties Nmap smb -vuln-ms17-010 des 2 Win-7.

Vulnerability		Severity	QoD	Host		Location	EPSS	
				IP	Name		Score	Percentile
SMB Brute Force Logins With Default Credentials		10.0 (Critical)	99 %	172.16.30.10	172.16.30.10	445/tcp	N/A	N/A

Vulnerability		Severity	QoD	Host		Location	EPSS	
				IP	Name		Score	Percentile
Microsoft SMB Transaction Parsing RCE Vulnerability		10.0 (Critical)	98 %	172.16.30.50	172.16.30.50	445/tcp	N/A	N/A
Operating System (OS) End of Life (EOL) Detection		10.0 (Critical)	80 %	172.16.30.50	172.16.30.50	general/tcp	N/A	N/A

Vulnerability		Severity	QoD	Host		Location	EPSS	
				IP	Name		Score	Percentile
SMB Brute Force Logins With Default Credentials		10.0 (Critical)	99 %	172.16.31.11	172.16.31.11	445/tcp	N/A	N/A

Vulnerability		Severity	QoD	Host		Location	EPSS	
				IP	Name		Score	Percentile
Operating System (OS) End of Life (EOL) Detection		10.0 (Critical)	80 %	172.16.31.10	172.16.31.10	general/tcp	N/A	N/A
Microsoft SMB Transaction Parsing RCE Vulnerability		10.0 (Critical)	98 %	172.16.31.10	172.16.31.10	445/tcp	N/A	N/A

Vulnerability		Severity	QoD	Host		Location	EPSS	
				IP	Name		Score	Percentile
Sudo Heap-Based Buffer Overflow Vulnerability (Baron Samedit) - Active Check		7.8 (High)	100 %	10.9.1.10	10.9.1.10	general/tcp	N/A	N/A

Vulnerability		Severity	QoD	Host		Location	EPSS	
				IP	Name		Score	Percentile
Cleartext Transmission of Sensitive Information via HTTP		4.8 (Medium)	80 %	172.16.30.11	172.16.30.11	80/tcp	N/A	N/A

```
┌──(uroot㉿uroot)-[~]
└─$ sudo nmap --script smb-vuln-ms17-010,smb2-security-mode 172.16.30.50 172.16.
31.10
[sudo] password for uroot:
Starting Nmap 7.99 ( https://nmap.org ) at 2026-10-07 14:01 +0000
Nmap scan report for 172.16.30.50 (172.16.30.50)
Host is up (0.079s latency).
Not shown: 988 closed tcp ports (reset)
PORT      STATE SERVICE
135/tcp   open  msrpc
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
3389/tcp  open  ms-wbt-server
5357/tcp  open  wsdapi
5985/tcp  open  wsman
49152/tcp open  unknown
49153/tcp open  unknown
49154/tcp open  unknown
49155/tcp open  unknown
49156/tcp open  unknown
49158/tcp open  unknown

Host script results:
| smb2-security-mode:
|   2.1:
|_    Message signing enabled but not required
| smb-vuln-ms17-010:
|   VULNERABLE:
|   Remote Code Execution vulnerability in Microsoft SMBv1 servers (ms17-010)
|     State: VULNERABLE
|     IDs:  CVE:CVE-2017-0143
|     Risk factor: HIGH
|       A critical remote code execution vulnerability exists in Microsoft SMBv1
|        servers (ms17-010).
|
|     Disclosure date: 2017-03-14
|     References:
|       https://technet.microsoft.com/en-us/library/security/ms17-010.aspx
|       https://blogs.technet.microsoft.com/msrc/2017/05/12/customer-guidance-fo
r-wannacrypt-attacks/
|_      https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2017-0143
```

```
Nmap scan report for 172.16.31.10 (172.16.31.10)
Host is up (0.14s latency).
Not shown: 988 closed tcp ports (reset)
PORT      STATE SERVICE
135/tcp   open  msrpc
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
3389/tcp  open  ms-wbt-server
5357/tcp  open  wsdapi
5985/tcp  open  wsman
49152/tcp open  unknown
49153/tcp open  unknown
49154/tcp open  unknown
49155/tcp open  unknown
49156/tcp open  unknown
49158/tcp open  unknown

Host script results:
| smb-vuln-ms17-010:
|   VULNERABLE:
|   Remote Code Execution vulnerability in Microsoft SMBv1 servers (ms17-010)
|     State: VULNERABLE
|     IDs:  CVE:CVE-2017-0143
|     Risk factor: HIGH
|       A critical remote code execution vulnerability exists in Microsoft SMBv1
|        servers (ms17-010).
|
|     Disclosure date: 2017-03-14
|     References:
|       https://technet.microsoft.com/en-us/library/security/ms17-010.aspx
|       https://blogs.technet.microsoft.com/msrc/2017/05/12/customer-guidance-fo
r-wannacrypt-attacks/
|_      https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2017-0143
| smb2-security-mode:
|   2.1:
|_    Message signing enabled but not required

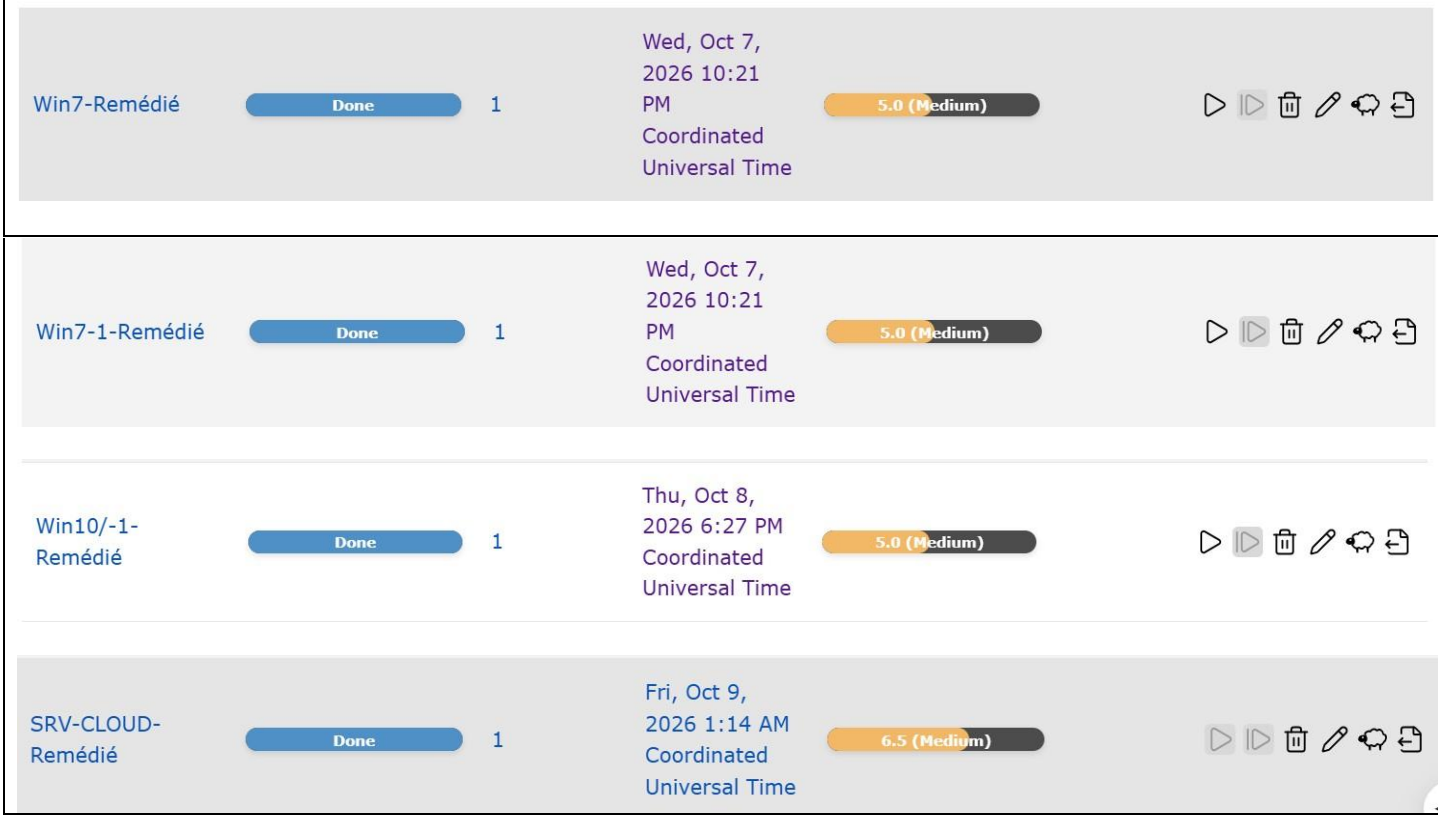
Nmap done: 2 IP addresses (2 hosts up) scanned in 24.39 seconds
```

5.3 Remédiation L2 + re-scan :

Actif	Action de remédiation	Re-scan : constat disparu (O/N)
Win-7 / Win-7-1	KB4012212 + SMBv1 off + mdp fort (reco : migration)	**O**
Windows-10 / -1	mdp fort + WinUpdate ON + restriction droits	**O**
SRV-CLOUD	mdp svc-app fort (reco : màj OS — scénario V-04 conservé)	**O**
Camera	mdp fort (fin d'admin/1234)	**O**

PREUVE 6

Rapport GCE L2 APRÈS : MS17-010 et constats corrigés disparus (V-04 conservé par scénario).



6. Atelier A — Matrice de risques RBVM

Multiplier le CVSS relevé par la criticité (§3), puis prioriser (P1 ≥ 25 · P2 = 10-24 · P3 < 10). Matrice pré-remplie avec les CVSS réels du P0 (02 et 05/10, L2 §4.2/§4.4) : V-01 — MS17-010 8.8 + Win 7 SP1 EOL 10.0 sur Win-7-1 ; V-03 — telnet 4.8 sur 5 IOS (SW-TOR : vérifier le planting puis re-scanner) ; Imprévu A — SMB sans mdp 10.0. F-01 : 10.0 argumenté. Lignes vides (V-02, V-05, V-07…) → scans authentifiés L1/L2 (S3).

Constat	Actif	Criticité	CVSS relevé	Risque = CVSS × Crit.	Priorité
V-04 — Ubuntu 20.04 gelé (EOL GCE non détecté) — Sudo CVE-2021-3156 réel 07/10	SRV-CLOUD	5	7.8 (Sudo)	**39** → P1	**P1** — màj sudo/kernel + migration OS (S4)
F-01 — cloud sans VPN (L3)	SRV-CLOUD / données	5	10.0	**50** → P1	**P1** — VPN IPSec Lab 4 (S5)
V-03 — telnet + SNMP v1 + guest	6 équipements IOS	4	4.8 (telnet)	**19,2** → P2 fort	**P2** — Lab 1 : SSH + SNMPv3, no guest
V-01 — MS17-010 + Win7 EOL	Win-7 / Win-7-1	3	10.0 (EOL) · 8.8 (MS17-010)	**30** et **26,4** → P1	**P1** — patch SMB + migration Win-7
V-05 — caméra :80 admin/1234	Camera	2	9.8	**19.6** → P2 fort	**P2** — changer le mdp « admin » (immédiat)
V-02 — Win10 EOL / WinRM clair	Windows-10 / -1	2	4.8	**9.6** → P3	**P3**
V-06 — terminaux non durcis	IP-Phone / -1	1	2.1	**2.1** → P3 faible	**P3**
Imprévu A (P0 réel) — SMB « administrator: » sans mot de passe	Windows-10	2	10.0	**20** → P2 fort	**P2** — changer le mdp « administrator » (immédiat)

Lecture métier : le cloud et le réseau se corrigent AVANT les postes. Apport du P0 réel : la priorisation n'est plus théorique — V-01 (26,4 / 30) monte P1 avec des CVSS relevés, V-03 (19,2) devient P2 fort (Lab 1), Imprévu A (20) réclame un correctif immédiat et gratuit (changer le mdp « administrator »). HTTP en clair renforce V-05.

6.1 Top 3 des priorités :

Rang	Constat	Risque	Justification métier
1	F-01 — cloud accessible sans VPN (exposition des données)	**50**	Données étudiants/DIWA joignables directement depuis internet en clair ; risque maximal, remédiation Lab 4 (IPSec, S5).
2	V-04 — SRV-CLOUD Ubuntu 20.04 gelé (Sudo Baron Samedit 7.8, réel 07/10)	**39**	Serveur porteur des données, OS figé (235 màj sécurité en attente); local root Sudo (CVE-2021-3156) confirmé par scan authentifié ; màj kernel/sudo + migration OS dès S4.
3	V-01 — Win-7 EOL + MS17-010 (P0 réel 05/10)	**30**	Exploitable sans credential (KEV CISA) mais poste de test isolé → P1 après le cloud ; patch SMB + migration.

6.2 Lien semaine 4 : la criticité est saisie comme attribut dans DefectDojo (Atelier B) — le risque y est recalculé par finding et sert de seuil de création automatique des tickets (P1 ≥ 25 → Jira + Mattermost).

7. Difficultés rencontrées et suite

Difficulté rencontrée	Solution / contournement
Aucune	**N**

Semaine 4 (obj 5) : L3/L4 — constat F-01 + remédiation IPSec/ACL ; en parallèle Atelier B — DefectDojo / Jira / Mattermost / Ansible (04 §10), alimentés par la matrice de cette semaine.

8. Critères de validation du livrable

[x] Rapport L1 avant + remédiation 6 IOS + re-scan SNMPv3
[x] Rapport L2 avant + Nmap MS17-010 + re-scan après
[x] Grille de criticité C1-C4 remplie (15 actifs)
[x] Matrice RBVM complète (CVSS réels × criticité → P1/P2/P3)
[x] Top 3 des priorités rédigé
[x] Difficultés consignées

Annexe A — Références croisées

06 (L1, L2, Atelier A) · 04 §6.5 (credentials) · 03 §7.5 (vulns IOS / remédiation) · 03 §4-§6 (SVI mgmt = cibles) · Livrable 2 (baseline P0, criticités initiales) · Chronogramme : semaine 3 = objectif 4.